

## Fiscalização TCE-RJ nº 18/2026 - iGovTI 2026

### Resposta do questionário 1

|                     |                                      |
|---------------------|--------------------------------------|
| ID da resposta      | 98                                   |
| Data de envio       | 2026-05-28 17:46:31.000              |
| Código de acesso    | zjFmNkamjbcgtJY                      |
| Data de início      | 2026-05-28 12:26:06.000              |
| Data da última ação | 2026-05-28 17:46:31.000              |
| Nome                | FTM                                  |
| Sobrenome           | Sergio Mauricio Nunes Tavares        |
| E-mail              | smtavares@theatromunicipal.rj.gov.br |

### Estrutura Organizacional e Força de Trabalho

|                                                                                                                                                                                                                                                                                                                                        |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 0101. Qual alternativa melhor descreve a formalização e o modelo de operação predominante da Tecnologia da Informação (TI) na organização? Identifica se a TI existe formalmente no organograma e como os recursos e serviços tecnológicos estão distribuídos física e administrativamente na organização.                             |
| f) Inexistente / Informal: Não há área de TI formalmente instituída no organograma da organização.                                                                                                                                                                                                                                     |
| Forneça como evidência a lei, decreto, portaria, regimento interno, organograma, contrato, convênio, termo de cooperação ou instrumento equivalente que demonstre o modelo de organização e prestação dos serviços de TI.                                                                                                              |
| filecount - Forneça como evidência a lei, decreto, portaria, regimento interno, organograma, contrato, convênio, termo de cooperação ou instrumento equivalente que demonstre o modelo de organização e prestação dos serviços de TI.                                                                                                  |
| 0102. Como a área de tecnologia da informação está posicionada na estrutura hierárquica da organização? Identifica o nível hierárquico da área de TI e sua proximidade com a alta administração, o que pode influenciar sua capacidade de coordenação institucional, priorização de demandas e participação nas decisões estratégicas. |
| e) não há área de TI formalmente instituída ou não há posicionamento hierárquico formal definido para a área de TI                                                                                                                                                                                                                     |
| Forneça como evidência o organograma institucional, regimento interno, lei, decreto, portaria ou instrumento equivalente que demonstre a posição hierárquica da área de TI.                                                                                                                                                            |
| filecount - Forneça como evidência o organograma institucional, regimento interno, lei, decreto, portaria ou instrumento equivalente que demonstre a posição hierárquica da área de TI.                                                                                                                                                |

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [a] a área de TI possui atribuições formalizadas relacionadas à sustentação de infraestrutura e serviços tecnológicos]

N/A

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [b] a área de TI possui atribuições formalizadas relacionadas ao desenvolvimento, manutenção ou integração de sistemas]

N/A

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [c] a área de TI possui atribuições formalizadas relacionadas à segurança da informação ou segurança cibernética]

N/A

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [d] a área de TI possui atribuições formalizadas relacionadas à governança, planejamento ou gestão de tecnologia da informação]

N/A

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [e] a área de TI possui atribuições formalizadas relacionadas à gestão de contratos e fornecedores de tecnologia da informação]

N/A

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [f] a área de TI possui atribuições formalizadas relacionadas à gestão de dados, análise de dados, automação ou inteligência artificial]

N/A

0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação. As atribuições da área de TI correspondem às competências, responsabilidades e atividades formalmente estabelecidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente. [g] não há atribuições ou competências da área de TI formalmente definidas em norma, regimento, organograma, ato administrativo ou instrumento equivalente]

Sim

Forneça evidência das atribuições formalizadas da área de TI, como: regimento interno; decreto; resolução; portaria; manual de competências; descrição formal de responsabilidades; ou outras evidências cabíveis.

filecount - Forneça evidência das atribuições formalizadas da área de TI, como: regimento interno; decreto; resolução; portaria; manual de competências; descrição formal de responsabilidades; ou outras evidências cabíveis.

0104. Como a função de Segurança da Informação (SI) está formalmente posicionada na estrutura organizacional? Identifica se a segurança da informação possui unidade, gestor, responsável, comitê ou instância formal, e se está integrada à TI, separada da TI ou organizada em estrutura colegiada.

e) Inexistente / Informal: Não há área, função, gestor ou comitê de Segurança da Informação formalmente instituído na organização.

Forneça como evidência o organograma normatizado ou a portaria de designação que demonstre a quem o gestor/comitê de Segurança da Informação está subordinado.

filecount - Forneça como evidência o organograma normatizado ou a portaria de designação que demonstre a quem o gestor/comitê de Segurança da Informação está subordinado.

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Tecnologia da Informação][Servidores efetivos ou empregados públicos]

2

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Tecnologia da Informação][Ocupantes exclusivamente de cargos em comissão (sem vínculo efetivo)]

2

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Tecnologia da Informação][Profissionais terceirizados ou contratados por empresas prestadoras de serviço]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Tecnologia da Informação][Servidores cedidos ou requisitados de outros órgãos]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Tecnologia da Informação][Contratados por tempo determinado (ex: Processo Seletivo Simplificado - PSS)]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Tecnologia da Informação][Estagiários e bolsistas]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Segurança da Informação][Servidores efetivos ou empregados públicos]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Segurança da Informação][Ocupantes exclusivamente de cargos em comissão (sem vínculo efetivo)]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Segurança da Informação][Profissionais terceirizados ou contratados por empresas prestadoras de serviço]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Segurança da Informação][Servidores cedidos ou requisitados de outros órgãos]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Segurança da Informação][Contratados por tempo determinado (ex: Processo Seletivo Simplificado - PSS)]

0

0105. Informe o quantitativo de profissionais que atuam regularmente em tecnologia da informação e segurança da informação, por área e tipo de vínculo. Esta questão permite avaliar a capacidade operacional da entidade, o grau de dependência de força de trabalho externa e a existência de pessoal dedicado às funções de TI e segurança da informação. [Segurança da Informação][Estagiários e bolsistas]

0

## Governança de Tecnologia da Informação

1001. A alta administração estabeleceu modelo de gestão de tecnologia da informação. O modelo de gestão de tecnologia da informação é o conjunto de diretrizes, estruturas, papéis e instâncias (como comitês) definidos pela alta administração para orientar, controlar e alinhar a TI às estratégias organizacionais.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização define as diretrizes para o planejamento de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização define as diretrizes para gestão de riscos de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a organização define os papéis e responsabilidades da área de gestão de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a organização designa responsáveis de cada área de negócio para a gestão dos respectivos sistemas informatizados]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] o comitê de tecnologia da informação realiza as atividades previstas em ato constitutivo]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g] a organização define as diretrizes para avaliação do desempenho dos serviços de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [h] a organização estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [i] a organização divulga os objetivos, indicadores e metas para a gestão de tecnologia da informação]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do modelo formal de gestão de TI, como: política ou norma de governança de TI aprovada pela alta administração; regimento do comitê de TI e atas que comprovem sua atuação; organograma com papéis e responsabilidades; designação formal de gestores de sistemas; diretrizes de planejamento, riscos e desempenho de TI; documentos com objetivos, indicadores e metas de TI; ou outras evidências cabíveis.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do modelo formal de gestão de TI, como: política ou norma de governança de TI aprovada pela alta administração; regimento do comitê de TI e atas que comprovem sua atuação; organograma com papéis e responsabilidades; designação formal de gestores de sistemas; diretrizes de planejamento, riscos e desempenho de TI; documentos com objetivos, indicadores e metas de TI; ou outras evidências cabíveis.

## Governança de Tecnologia da Informação

1002. A alta administração monitora o desempenho da gestão de tecnologia da informação. O monitoramento do desempenho de TI é o acompanhamento sistemático, pela alta administração, de indicadores, metas e resultados da gestão de TI, para avaliar desempenho e orientar decisões.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) há acompanhamento na execução dos planos vigentes quanto ao alcance das metas estabelecidas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) os indicadores de desempenho da gestão de tecnologia da informação estão implantados (há coleta e análise dos dados necessários à medição de desempenho)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) relatórios de medição de desempenho da gestão de tecnologia da informação estão disponíveis à liderança]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do monitoramento do desempenho de TI, como: norma ou procedimento que estabeleça rotinas de monitoramento; painel ou sistema com indicadores e metas de TI; relatórios periódicos de desempenho; atas de reuniões da alta administração ou comitê de TI com análise de resultados; evidências de acompanhamento do plano de TI; ou outras evidências cabíveis.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do monitoramento do desempenho de TI, como: norma ou procedimento que estabeleça rotinas de monitoramento; painel ou sistema com indicadores e metas de TI; relatórios periódicos de desempenho; atas de reuniões da alta administração ou comitê de TI com análise de resultados; evidências de acompanhamento do plano de TI; ou outras evidências cabíveis.

## Governança de Tecnologia da Informação

1003. A instância superior de governança recebe serviços de auditoria interna que adicionam valor à organização. Os serviços de auditoria interna agregam valor quando avaliam riscos, controles e governança, apoiando a alta administração com recomendações para melhoria da gestão, inclusive de TI e segurança da informação.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] os serviços de auditoria interna prestados anualmente para a organização contemplam avaliação da gestão de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] os serviços de auditoria interna prestados anualmente para a organização contemplam avaliação da gestão de segurança da informação]

N/A

Caso tenha assinalado que adota a prática, forneça evidência dos serviços de auditoria interna, como: plano anual de auditoria baseado em riscos; relatórios de auditoria que abranjam governança, riscos críticos, TI e segurança da informação; pareceres sobre confiabilidade das prestações de contas; atas ou comunicações à instância superior; evidências de acompanhamento das recomendações; ou outras evidências cabíveis.

filecount - Caso tenha assinalado que adota a prática, forneça evidência dos serviços de auditoria interna, como: plano anual de auditoria baseado em riscos; relatórios de auditoria que abranjam governança, riscos críticos, TI e segurança da informação; pareceres sobre confiabilidade das prestações de contas; atas ou comunicações à instância superior; evidências de acompanhamento das recomendações; ou outras evidências cabíveis.

## Governança de Tecnologia da Informação

1004. A organização definiu metas para a simplificação do atendimento prestado aos usuários dos serviços públicos. As metas de simplificação do atendimento são objetivos definidos para ampliar serviços digitais, reduzir burocracia e melhorar a experiência do usuário nos serviços públicos.

Não adota.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] há metas para a ampliação da oferta de serviços públicos prestados em meio digital]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] há metas com vistas à eliminação da exigência de atestados, certidões ou outros documentos comprobatórios que constem em base de dados oficial da administração pública federal, como condição para a prestação de serviços]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] há metas para reduzir a necessidade de atendimento presencial dos usuários em todas as etapas de prestação dos serviços públicos (p. ex.: por meio da automação completa das etapas de: solicitação, acompanhamento de solicitações, execução de procedimentos e comunicação de resultados)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] há metas voltadas à melhoria e ao incremento da atuação integrada e sistêmica com outros órgãos e entidades dos quais dependa ou com os quais interaja intensivamente na prestação dos serviços públicos, tais como metas de compartilhamento de dados e metas de interoperabilidade relacionadas à adoção de procedimentos, ferramentas e plataformas comuns (p. ex.: Plataforma de Cidadania Digital)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] há metas com vistas a otimizar o uso de múltiplos canais de atendimento (p. ex.: canal presencial, telefone, canal digital/internet, aplicativos móveis, correio eletrônico etc.), de modo a assegurar que canal adequado esteja disponível para usuários com necessidades especiais e, no caso de serviços críticos e relevantes, que canais alternativos estejam disponíveis, se falhar o canal principal]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] a organização utiliza a gestão de riscos como instrumento para promover a simplificação de procedimentos associados à prestação de serviços públicos, de modo a assegurar que somente sejam utilizados os controles indispensáveis, de acordo com os limites de exposição a riscos institucionalmente definidos, e que sejam eliminados controles desnecessários ou economicamente desvantajosos]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g] a organização utiliza os resultados das pesquisas de satisfação como subsídio para promover melhoria na prestação dos serviços]

N/A

Caso tenha assinalado que adota a prática, forneça evidência das metas de simplificação, como: plano ou estratégia de transformação digital com metas definidas; indicadores e metas para digitalização de serviços; metas de redução de atendimento presencial ou de exigências documentais; iniciativas de interoperabilidade e integração; relatórios de acompanhamento; resultados de pesquisas de satisfação utilizados para melhorias; ou outras evidências cabíveis.

filecount - Caso tenha assinalado que adota a prática, forneça evidência das metas de simplificação, como: plano ou estratégia de transformação digital com metas definidas; indicadores e metas para digitalização de serviços; metas de redução de atendimento presencial ou de exigências documentais; iniciativas de interoperabilidade e integração; relatórios de acompanhamento; resultados de pesquisas de satisfação utilizados para melhorias; ou outras evidências cabíveis.

## Gestão de Tecnologia da Informação

Confirme para prosseguir para a próxima seção. [Estou ciente das informações apresentadas.]

Sim

## Planejamento de Tecnologia da Informação

2101. A organização executa processo de planejamento de tecnologia da informação. O processo de planejamento de TI é o conjunto de atividades formais para definir, priorizar e revisar iniciativas de TI, alinhadas às necessidades institucionais e com participação das áreas envolvidas.

Não adota.

Indique que leis e/ou normas são essas:

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] as áreas demandantes de soluções de TI participam do processo de planejamento de tecnologia da informação]                                                                                                                                                                                                                                                                            |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados]                                                                                                                                                                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações)]                                                                                                                                                                                                                               |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]                                                                                                                                                                                |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Caso tenha assinalado que adota a prática, forneça evidência do processo de planejamento de TI, como: norma ou procedimento formal que discipline o planejamento; plano de TI vigente (ex.: PEDTIC/PDTI/PEI de TI); registros de participação das áreas demandantes; critérios de priorização documentados; estudos de custo, benefício e risco; atas de reuniões de planejamento; evidências de integração com planejamento institucional; relatórios de avaliação e revisão do processo; ou outras evidências cabíveis.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de planejamento de TI, como: norma ou procedimento formal que discipline o planejamento; plano de TI vigente (ex.: PEDTIC/PDTI/PEI de TI); registros de participação das áreas demandantes; critérios de priorização documentados; estudos de custo, benefício e risco; atas de reuniões de planejamento; evidências de integração com planejamento institucional; relatórios de avaliação e revisão do processo; ou outras evidências cabíveis. |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |

## Planejamento de Tecnologia da Informação

|                                                                                                                                                                                                                                                                                                                   |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2102. A organização possui plano de tecnologia da informação vigente.O plano de TI é o documento que consolida objetivos, iniciativas e ações de tecnologia, alinhado à estratégia institucional e utilizado para orientar investimentos, contratações e execução da TI.                                          |
| Adota em menor parte.                                                                                                                                                                                                                                                                                             |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                           |
|                                                                                                                                                                                                                                                                                                                   |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                        |
|                                                                                                                                                                                                                                                                                                                   |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                    |
|                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração] |
| N/A                                                                                                                                                                                                                                                                                                               |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) o plano de TI é publicado na internet, para fácil acesso de partes interessadas e da sociedade]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no planejamento institucional (como PPA, planos estratégicos, planos setoriais e plano de governo, no caso de municípios), bem como, quando aplicável, às estratégias e diretrizes estabelecidas por instâncias superiores de governança (como a Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD, normas e orientações do SETIC/PRODERJ (para órgãos estaduais) ou instâncias de governança equivalentes no âmbito municipal)] |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário]                                                                                                                                                                                                                                                                                                                                                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Caso tenha assinalado que adota a prática, forneça evidência do plano de TI, como: documento vigente aprovado pela alta administração; publicação do plano (se aplicável); vinculação com orçamento e plano de contratações; alinhamento com planejamento institucional; relatórios ou atas de acompanhamento da execução; indicadores e revisões do plano; ou outras evidências cabíveis, indicando a abrangência na organização.                                                                                                                                                                                                                                                                                                              |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência do plano de TI, como: documento vigente aprovado pela alta administração; publicação do plano (se aplicável); vinculação com orçamento e plano de contratações; alinhamento com planejamento institucional; relatórios ou atas de acompanhamento da execução; indicadores e revisões do plano; ou outras evidências cabíveis, indicando a abrangência na organização.                                                                                                                                                                                                                                                                                                  |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

## Gestão de Serviços de Tecnologia da Informação

|                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2201. A organização elabora um catálogo de serviços de tecnologia da informação e monitora níveis de serviço. O catálogo de serviços de TI descreve os serviços prestados, seus níveis de atendimento e responsáveis, permitindo acordar, monitorar e melhorar a qualidade dos serviços oferecidos aos usuários.                                                                                     |
| Não adota.                                                                                                                                                                                                                                                                                                                                                                                           |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                              |
|                                                                                                                                                                                                                                                                                                                                                                                                      |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                           |
|                                                                                                                                                                                                                                                                                                                                                                                                      |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                       |
|                                                                                                                                                                                                                                                                                                                                                                                                      |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes)] |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização]                                     |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte]                                                                                                                                                   |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                  |

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do catálogo e da gestão de níveis de serviço, como: catálogo de serviços vigente (ex.: portal, documento ou sistema); ANS firmados com secretarias/áreas usuárias; definição de metas (prazos, disponibilidade, suporte); registros de monitoramento dos níveis de serviço; relatórios de desempenho; canais de atendimento definidos; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do catálogo e da gestão de níveis de serviço, como: catálogo de serviços vigente (ex.: portal, documento ou sistema); ANS firmados com secretarias/áreas usuárias; definição de metas (prazos, disponibilidade, suporte); registros de monitoramento dos níveis de serviço; relatórios de desempenho; canais de atendimento definidos; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Serviços de Tecnologia da Informação

2202. A organização executa processo de gestão de mudanças. A gestão de mudanças é o processo de planejar, avaliar, aprovar, implementar e monitorar alterações em serviços e sistemas de TI, reduzindo riscos e impactos aos usuários.

Não adota.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização estabeleceu critérios para orientar a aprovação de mudanças, inclusive quanto ao tratamento de casos de exceção (mudanças emergenciais)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] mudanças são previamente comunicadas a todas as partes que possam ser afetadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] identificam-se os serviços e ativos de TI que possam ser afetados pela mudança, de modo a avaliar impactos em níveis de serviços acordados]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a realização de cada mudança é precedida de planejamento e testes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] mudanças executadas são rastreáveis e monitoradas, com vistas à avaliação de sua efetividade e para permitir ações corretivas, no caso de ocorrência de efeitos não identificados nas fases de planejamento e testes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) o processo de gestão de mudanças está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do processo de gestão de mudanças, como: norma ou procedimento formal; registros de solicitações e aprovações de mudanças (incluindo emergenciais); planos e evidências de testes; comunicações às áreas impactadas; registros de impactos e serviços afetados; logs ou sistemas de rastreabilidade; relatórios de avaliação pós-implementação; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de gestão de mudanças, como: norma ou procedimento formal; registros de solicitações e aprovações de mudanças (incluindo emergenciais); planos e evidências de testes; comunicações às áreas impactadas; registros de impactos e serviços afetados; logs ou sistemas de rastreabilidade; relatórios de avaliação pós-implementação; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Serviços de Tecnologia da Informação

2203. A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação). A gestão de configuração e ativos é o controle dos recursos de TI e suas relações, garantindo informações confiáveis para operação, mudanças e tomada de decisão.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a base de dados de configurações é utilizada como insumo para o planejamento e o acompanhamento das mudanças]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da gestão de configuração e ativos, como: inventário atualizado de ativos e serviços de TI; base de dados de configuração (CMDB ou equivalente); registros de relacionamento entre sistemas, infraestrutura e serviços; uso dessas informações em mudanças; norma ou procedimento formal; relatórios ou ferramentas de controle; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão de configuração e ativos, como: inventário atualizado de ativos e serviços de TI; base de dados de configuração (CMDB ou equivalente); registros de relacionamento entre sistemas, infraestrutura e serviços; uso dessas informações em mudanças; norma ou procedimento formal; relatórios ou ferramentas de controle; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Serviços de Tecnologia da Informação

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2204. A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação. A gestão de incidentes trata da identificação, registro, priorização e resolução de falhas em serviços e segurança da informação, visando restabelecer rapidamente o serviço e reduzir impactos.                                                                                                                                                                                |
| Adota em menor parte.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização definiu regras para a priorização e o escalamento de incidentes]                                                                                                                                                                                                                                                                                                      |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a resolução de incidentes considera os níveis de serviços especificados em acordos com as áreas clientes]                                                                                                                                                                                                                                                                           |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] há base(s) de conhecimento que registra(m) erros conhecidos e problemas, de modo a tornar eficiente e efetiva a resolução de incidentes]                                                                                                                                                                                                                                            |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]                                                                                                                                                               |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a organização definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa]                                                                                                                |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] a organização definiu procedimentos e responsabilidades quanto à análise dos incidentes, identificação de causas raízes e planejamento e implementação de ações corretivas]                                                                                                                                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Caso tenha assinalado que adota a prática, forneça evidência da gestão de incidentes, como: norma ou procedimento formal; registros de incidentes (chamados/tickets); critérios de priorização e escalonamento; base de conhecimento com erros conhecidos; relatórios de atendimento e tempos de resolução; evidências de tratamento de incidentes de segurança (notificação, resposta e comunicação); análise de causa raiz e ações corretivas; ou outras evidências cabíveis, indicando a abrangência na organização.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão de incidentes, como: norma ou procedimento formal; registros de incidentes (chamados/tickets); critérios de priorização e escalonamento; base de conhecimento com erros conhecidos; relatórios de atendimento e tempos de resolução; evidências de tratamento de incidentes de segurança (notificação, resposta e comunicação); análise de causa raiz e ações corretivas; ou outras evidências cabíveis, indicando a abrangência na organização. |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

## Gestão de Riscos de TI e Segurança da Informação

2301. A organização executa processo de gestão dos riscos de tecnologia da informação relativos a processos de negócio. A gestão de riscos de TI é o processo de identificar, avaliar e tratar riscos que possam afetar sistemas, serviços e processos de negócio, reduzindo impactos e apoiando decisões.

Não adota.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização identifica e avalia os riscos associados com o uso de Tecnologia da Informação nos processos organizacionais críticos para o negócio (Riscos de TI)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização trata os Riscos de TI com base em um plano de tratamento de risco]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o processo de gestão dos riscos de tecnologia da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da gestão de riscos de TI, como: matriz de riscos de TI vinculada a processos de negócio; critérios de avaliação e priorização; planos de tratamento; relatórios de acompanhamento; registros de revisão periódica; norma ou procedimento formal; evidências de integração com riscos institucionais; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão de riscos de TI, como: matriz de riscos de TI vinculada a processos de negócio; critérios de avaliação e priorização; planos de tratamento; relatórios de acompanhamento; registros de revisão periódica; norma ou procedimento formal; evidências de integração com riscos institucionais; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Riscos de TI e Segurança da Informação

2302. A organização executa processo de gestão de riscos de segurança da informação. A gestão de riscos de segurança da informação identifica, avalia e trata ameaças à confidencialidade, integridade e disponibilidade das informações e dos serviços.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização identifica e avalia riscos de segurança da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização trata riscos de segurança da informação com base em um plano de tratamento de riscos]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) a organização possui um gestor formalmente responsável por coordenar a gestão de riscos de segurança da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) o processo de gestão de riscos de segurança da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da gestão de riscos de segurança da informação, como: matriz ou inventário de riscos; registros de identificação e avaliação (impacto e probabilidade); planos de tratamento com responsáveis e prazos; designação formal de responsável; norma ou procedimento institucional; relatórios de acompanhamento; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão de riscos de segurança da informação, como: matriz ou inventário de riscos; registros de identificação e avaliação (impacto e probabilidade); planos de tratamento com responsáveis e prazos; designação formal de responsável; norma ou procedimento institucional; relatórios de acompanhamento; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Riscos de TI e Segurança da Informação

2303. A organização executa processo de gestão de continuidade de serviços de tecnologia da informação. A gestão de continuidade de TI garante que serviços e sistemas críticos possam ser mantidos ou recuperados em caso de falhas, desastres ou interrupções.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) a organização elabora um plano de continuidade de serviços de TI]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) as ações e os prazos definidos no plano de continuidade de serviços de TI fundamentam-se em análises de impacto no negócio (AIN/BIA) realizadas sobre os processos organizacionais críticos]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) o plano de continuidade de serviços de TI é testado e revisado periodicamente]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) o processo de gestão de continuidade de serviços de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da continuidade de serviços de TI, como: plano de continuidade ou de recuperação de desastres (PCN/DRP); análises de impacto no negócio (BIA/AIN); definição de prazos de recuperação (RTO/RPO); registros de testes e revisões do plano; norma ou procedimento formal; relatórios de incidentes relevantes; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da continuidade de serviços de TI, como: plano de continuidade ou de recuperação de desastres (PCN/DRP); análises de impacto no negócio (BIA/AIN); definição de prazos de recuperação (RTO/RPO); registros de testes e revisões do plano; norma ou procedimento formal; relatórios de incidentes relevantes; ou outras evidências cabíveis, indicando a abrangência na organização.

## Estrutura de Segurança da Informação

2401. A organização dispõe de uma política de segurança da informação. A política de segurança da informação define diretrizes e responsabilidades para proteger dados e sistemas, assegurando confidencialidade, integridade e disponibilidade das informações.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a política declara o comprometimento da alta administração e estabelece princípios, diretrizes, objetivos, estruturas e responsabilidades relativos à segurança da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a política (ou norma interna complementar) contempla diretrizes sobre gestão de riscos de segurança da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a política abrange diretrizes para conscientização, treinamento e educação em segurança da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a política é amplamente comunicada a empregados, servidores, colaboradores e partes externas relevantes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a política é mantida atualizada, por meio de revisões periódicas]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da política de segurança da informação, como: documento formal aprovado pela alta administração; conteúdo com diretrizes, responsabilidades e gestão de riscos; registros de comunicação e divulgação; ações de conscientização e treinamento; histórico de revisões; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da política de segurança da informação, como: documento formal aprovado pela alta administração; conteúdo com diretrizes, responsabilidades e gestão de riscos; registros de comunicação e divulgação; ações de conscientização e treinamento; histórico de revisões; ou outras evidências cabíveis, indicando a abrangência na organização.

## Estrutura de Segurança da Informação

|                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2402. A organização dispõe de comitê de segurança da informação. O comitê de segurança da informação é a instância que coordena decisões, diretrizes e ações para proteger dados e sistemas, envolvendo áreas relevantes da organização.                                                                                                                                                                         |
| Não adota.                                                                                                                                                                                                                                                                                                                                                                                                       |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                                          |
|                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                       |
|                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                   |
|                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] o comitê de segurança da informação realiza as atividades previstas em seu ato constitutivo]                                                                                                                                                                     |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                              |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] o comitê formula diretrizes para a segurança da informação]                                                                                                                                                                                                      |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                              |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o comitê propõe a elaboração e a revisão de normas e de procedimentos inerentes à segurança da informação]                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                              |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] o comitê é composto por representantes de áreas relevantes da organização]                                                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                              |
| Caso tenha assinalado que adota a prática, forneça evidência do comitê de segurança da informação, como: ato de criação com competências definidas; composição com representantes de áreas relevantes; atas de reuniões; deliberações sobre diretrizes, normas e ações de segurança; registros de acompanhamento de decisões; ou outras evidências cabíveis, indicando a abrangência na organização.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                  |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência do comitê de segurança da informação, como: ato de criação com competências definidas; composição com representantes de áreas relevantes; atas de reuniões; deliberações sobre diretrizes, normas e ações de segurança; registros de acompanhamento de decisões; ou outras evidências cabíveis, indicando a abrangência na organização. |
|                                                                                                                                                                                                                                                                                                                                                                                                                  |

## Estrutura de Segurança da Informação

|                                                                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2403. A organização possui um gestor institucional de segurança da informação. O gestor de segurança da informação é o responsável por coordenar políticas, riscos e ações de proteção de dados e sistemas, com autoridade definida pela alta administração. |
| Não adota.                                                                                                                                                                                                                                                   |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                      |
|                                                                                                                                                                                                                                                              |
| Identifique esses estudos:                                                                                                                                                                                                                                   |
|                                                                                                                                                                                                                                                              |
| Explique que razões são essas:                                                                                                                                                                                                                               |
|                                                                                                                                                                                                                                                              |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] o gestor institucional de segurança da informação foi designado formalmente pela alta administração]         |
| N/A                                                                                                                                                                                                                                                          |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) o gestor institucional de segurança da informação reporta-se diretamente à alta administração]                                                                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) o gestor institucional de segurança da informação coordena o processo de gestão de riscos de segurança da informação em âmbito institucional]                                                                                                                                                        |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) o gestor institucional de segurança da informação coordena ações de segurança da informação em âmbito institucional]                                                                                                                                                                                 |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) o gestor institucional de segurança da informação fomenta e coordena ações periódicas de conscientização e de treinamento em segurança da informação para todas as partes interessadas, incluindo autoridades, servidores e colaboradores]                                                           |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) o gestor institucional de segurança da informação detém as prerrogativas e os recursos necessários para o desempenho de todas as suas competências]                                                                                                                                                  |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Caso tenha assinalado que adota a prática, forneça evidência do gestor de segurança da informação, como: ato formal de designação; descrição de atribuições e vínculo com a alta administração; registros de atuação na coordenação de riscos e ações de segurança; evidências de campanhas de conscientização e treinamentos; estrutura ou recursos disponíveis; ou outras evidências cabíveis, indicando a abrangência na organização.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência do gestor de segurança da informação, como: ato formal de designação; descrição de atribuições e vínculo com a alta administração; registros de atuação na coordenação de riscos e ações de segurança; evidências de campanhas de conscientização e treinamentos; estrutura ou recursos disponíveis; ou outras evidências cabíveis, indicando a abrangência na organização. |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

## Estrutura de Segurança da Informação

|                                                                                                                                                                                                                                                        |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2404. A organização possui um responsável pelo tratamento e resposta a incidentes. O responsável por incidentes coordena a detecção, análise e resposta a eventos de segurança, reduzindo impactos e restabelecendo serviços com rapidez.              |
| Não adota.                                                                                                                                                                                                                                             |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                |
|                                                                                                                                                                                                                                                        |
| Identifique esses estudos:                                                                                                                                                                                                                             |
|                                                                                                                                                                                                                                                        |
| Explique que razões são essas:                                                                                                                                                                                                                         |
|                                                                                                                                                                                                                                                        |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) o responsável ou equipe (ex.: ETIR) foi designado formalmente pela alta administração]                 |
| N/A                                                                                                                                                                                                                                                    |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) o responsável ou equipe (ex.: ETIR) detecta, registra e analisa incidentes de segurança da informação] |
| N/A                                                                                                                                                                                                                                                    |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o responsável ou equipe (ex.: ETIR) utiliza informações sobre vulnerabilidades para apoiar a prevenção e resposta a incidentes]                                                                                                                                                                                                                                                          |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] o responsável ou equipe (ex.: ETIR) recebe e trata notificações relacionadas a incidentes de segurança da informação]                                                                                                                                                                                                                                                                    |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] o responsável ou equipe (ex.: ETIR) coordena e executa atividades de tratamento e resposta a eventos de segurança da informação]                                                                                                                                                                                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] o responsável ou equipe (ex.: ETIR) realiza a comunicação de incidentes às partes interessadas internas e externas, conforme critérios definidos]                                                                                                                                                                                                                                        |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g] o responsável ou equipe (ex.: ETIR) realiza análise pós-incidente para identificar causas e propor melhorias]                                                                                                                                                                                                                                                                            |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Caso tenha assinalado que adota a prática, forneça evidência do responsável por incidentes, como: ato formal de designação; descrição de competências; evidências da atuação de equipe de resposta a incidentes (ex.: ETIR); registros de monitoramento e análise de eventos; relatórios de incidentes tratados; registros de vulnerabilidades identificadas; comunicações e respostas a incidentes; evidências de coordenação das ações de resposta; ou outras evidências cabíveis, indicando a abrangência na organização.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência do responsável por incidentes, como: ato formal de designação; descrição de competências; evidências da atuação de equipe de resposta a incidentes (ex.: ETIR); registros de monitoramento e análise de eventos; relatórios de incidentes tratados; registros de vulnerabilidades identificadas; comunicações e respostas a incidentes; evidências de coordenação das ações de resposta; ou outras evidências cabíveis, indicando a abrangência na organização. |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

## Processos de Segurança da Informação

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2501. A organização executa processo de gestão de ativos associados à informação. A gestão de ativos associados à informação consiste em identificar, inventariar, classificar e acompanhar ativos que armazenam, processam ou transmitem informações, assegurando sua proteção durante todo o ciclo de vida. Exemplos: sistema de prontuário eletrônico da saúde, sistema de arrecadação tributária, folha de pagamento, portal do aluno, backups, banco de dados de cidadãos, servidores, notebooks e documentos digitais que contenham informações críticas ou dados pessoais. |
| Adota em menor parte.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização mantém um inventário dos ativos associados à informação]                                                                                                                                                                                                                                                                                                                                                            |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização definiu responsabilidades pelos ativos associados à informação]                                                                                                                                                                                                                                                                                                                                                     |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) o inventário identifica as informações críticas que os ativos armazenam, processam ou transmitem]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) o processo de gestão de ativos associados à informação subsidia a implantação de controles e ações com vistas a assegurar a adequada proteção dos ativos e das informações que armazenam, processam ou transmitem]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) o processo de gestão de ativos associados à informação subsidia a implantação de ações mitigatórias aplicáveis no caso de ocorrência de evento catastrófico que inviabilize a utilização de ativos]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) o processo de gestão de ativos associados à informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da gestão de ativos associados à informação, como: inventário de ativos e informações críticas; definição formal de responsáveis pelos ativos; classificação ou identificação de informações sensíveis ou críticas; registros de controles de proteção aplicados; planos ou ações mitigatórias para indisponibilidade de ativos críticos; norma ou procedimento formal; relatórios de acompanhamento ou revisão do processo; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão de ativos associados à informação, como: inventário de ativos e informações críticas; definição formal de responsáveis pelos ativos; classificação ou identificação de informações sensíveis ou críticas; registros de controles de proteção aplicados; planos ou ações mitigatórias para indisponibilidade de ativos críticos; norma ou procedimento formal; relatórios de acompanhamento ou revisão do processo; ou outras evidências cabíveis, indicando a abrangência na organização.

## Processos de Segurança da Informação

2502. A organização executa processo de controle de acesso à informação e aos ativos associados à informação. O controle de acesso consiste em definir, conceder, revisar e revogar acessos físicos e lógicos à informação e aos ativos associados, assegurando que apenas usuários autorizados tenham acesso adequado às informações e serviços.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) a organização implementa controles de acesso físicos e lógicos à informação e aos ativos associados à informação que são por ela gerenciados ou custodiados, com vistas a proteger adequadamente a confidencialidade das informações não públicas e a integridade e a disponibilidade das informações consideradas críticas para o negócio]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) os controles de acesso implementados na organização aplicam o princípio "necessidade de conhecer", o qual prescreve que deve haver necessidade legítima que justifique o acesso à informação por pessoa, sistema ou entidade, bem como o princípio "privilegio mínimo", o qual estabelece que o perfil de acesso concedido deve incluir tão somente os poderes necessários para o atendimento das legítimas necessidades]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) há controles de acesso lógicos na organização que utilizam autenticação com certificado digital ICP-Brasil, a fim de prover identificação inequívoca de pessoas físicas e jurídicas e comprovação de autoria em transações digitais]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) a organização analisa criticamente, a intervalos regulares, os direitos de acesso lógicos e físicos existentes, com vistas à remoção de direitos que deixaram de ser necessários e para assegurar que privilégios indevidos não foram obtidos]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) a organização instituiu uma Política de Controle de Acesso (PCA), a qual estabelece princípios, objetivos, diretrizes, principais atividades e responsabilidades relativos ao processo de controle de acesso]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do processo de controle de acesso, como: Política de Controle de Acesso (PCA); normas ou procedimentos de concessão, revisão e revogação de acessos; perfis e matrizes de acesso; registros de revisões periódicas de privilégios; evidências de autenticação forte ou uso de certificado digital; logs de acesso; relatórios de monitoramento; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de controle de acesso, como: Política de Controle de Acesso (PCA); normas ou procedimentos de concessão, revisão e revogação de acessos; perfis e matrizes de acesso; registros de revisões periódicas de privilégios; evidências de autenticação forte ou uso de certificado digital; logs de acesso; relatórios de monitoramento; ou outras evidências cabíveis, indicando a abrangência na organização.

## Processos de Segurança da Informação

2503. A organização executa processo para classificação e tratamento de informações. A classificação e tratamento de informações consiste em identificar informações conforme sua criticidade, sensibilidade ou sigilo e aplicar medidas adequadas de proteção, armazenamento, acesso e compartilhamento, de acordo com requisitos legais e de negócio.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) informações pessoais são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) a organização informa em seu sítio eletrônico as hipóteses em que, no exercício de suas competências, realiza o tratamento de dados pessoais, bem como fornece informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas de tratamento que utiliza]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) informações sigilosas em razão de sua imprescindibilidade à segurança da sociedade ou do Estado são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) informações sigilosas em função de outras hipóteses legais de sigilo ou segredo são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] informações críticas para a organização em razão de necessidades do negócio (p. ex. requisitos associados à integridade, disponibilidade, autenticidade ou a outros atributos da informação) são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] o processo de classificação e tratamento de informações está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do processo de classificação e tratamento de informações, como: política ou norma de classificação da informação; critérios de classificação e rotulagem; inventários ou registros de informações críticas, pessoais ou sigilosas; procedimentos de tratamento e proteção; controles de acesso e armazenamento; evidências de adequação à LGPD e à LAI; registros de revisão periódica; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de classificação e tratamento de informações, como: política ou norma de classificação da informação; critérios de classificação e rotulagem; inventários ou registros de informações críticas, pessoais ou sigilosas; procedimentos de tratamento e proteção; controles de acesso e armazenamento; evidências de adequação à LGPD e à LAI; registros de revisão periódica; ou outras evidências cabíveis, indicando a abrangência na organização.

## Processos de Segurança da Informação

2504. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem. A gestão da segurança dos recursos de processamento da informação consiste em proteger dispositivos, sistemas, redes, aplicações e ambientes de TI contra acessos indevidos, falhas, vulnerabilidades e ameaças cibernéticas, incluindo ambientes locais, terceirizados e em nuvem.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização gerencia (inventaria e controla) os dispositivos conectados em sua rede]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização gerencia (inventaria e controla) os softwares instalados nos dispositivos conectados em sua rede]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a organização gerencia vulnerabilidades técnicas em seus ativos de software, de hardware e de rede críticos para o negócio]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a organização implementa configurações seguras em seus ativos de software, de hardware e de rede críticos para o negócio]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a organização mantém, monitora e analisa logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] a organização aplica controles compensatórios para o uso de privilégios administrativos em seus ativos de software, de hardware e de rede críticos para o negócio]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g] a organização implementa defesas contra malware (ex: vírus) e outras ameaças cibernéticas (ex: phishing)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [h] a organização limita e controla o uso de portas, protocolos e serviços de rede nas conexões de sua rede interna com a internet e outras redes externas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [i] a organização implementa defesa de perímetro das conexões de sua rede interna com a internet e outras redes externas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [j] a organização implementa cópias regulares de segurança (backup) das informações em meio digital, conforme as melhores práticas e as necessidades de negócio, incluindo a realização periódica de testes de recuperação das informações]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [k] a organização executa regularmente testes de segurança em seu ambiente de TI (detecção de vulnerabilidades e testes de penetração)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da gestão da segurança dos recursos de processamento da informação, como: inventário de dispositivos e softwares; registros de gestão de vulnerabilidades e aplicação de correções; padrões de configuração segura; logs e relatórios de monitoramento; controles de privilégios administrativos; evidências de antivírus, firewall e proteção contra malware; políticas e registros de backup e testes de recuperação; relatórios de testes de segurança; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão da segurança dos recursos de processamento da informação, como: inventário de dispositivos e softwares; registros de gestão de vulnerabilidades e aplicação de correções; padrões de configuração segura; logs e relatórios de monitoramento; controles de privilégios administrativos; evidências de antivírus, firewall e proteção contra malware; políticas e registros de backup e testes de recuperação; relatórios de testes de segurança; ou outras evidências cabíveis, indicando a abrangência na organização.

## Processos de Segurança da Informação

2505. A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação. As ações de treinamento, capacitação e conscientização em segurança da informação buscam orientar servidores, colaboradores e usuários sobre riscos, boas práticas e responsabilidades relacionadas à proteção das informações e dos recursos de TI.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

|                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                                            |
|                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização realiza ações de capacitação voltadas para segurança da informação]                                                                                                                                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização participa de ações de capacitação voltadas para segurança da informação]                                                                                                                                                                                                    |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a organização realiza ações de conscientização em segurança de TIC]                                                                                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a organização possui programa permanente de conscientização em segurança da informação]                                                                                                                                                                                                   |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Caso tenha assinalado que adota a prática, forneça evidência das ações de treinamento e conscientização em segurança da informação, como: plano ou programa de capacitação; registros de treinamentos realizados; campanhas de conscientização; materiais educativos; listas de presença; certificados; comunicações internas; cronogramas periódicos; ou outras evidências cabíveis, indicando a abrangência na organização.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência das ações de treinamento e conscientização em segurança da informação, como: plano ou programa de capacitação; registros de treinamentos realizados; campanhas de conscientização; materiais educativos; listas de presença; certificados; comunicações internas; cronogramas periódicos; ou outras evidências cabíveis, indicando a abrangência na organização. |
|                                                                                                                                                                                                                                                                                                                                                                                                                                           |

## Gestão de Soluções e Projetos de TI

|                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2601. A organização executa um processo de software. O processo de software consiste em definir e executar atividades para desenvolvimento, manutenção, sustentação ou aquisição de sistemas, incluindo requisitos de negócio, segurança, acessibilidade, qualidade e responsabilidades ao longo do ciclo de vida do software.<br>Adota em menor parte.                        |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                        |
|                                                                                                                                                                                                                                                                                                                                                                                |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                     |
|                                                                                                                                                                                                                                                                                                                                                                                |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                 |
|                                                                                                                                                                                                                                                                                                                                                                                |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] o processo de software utilizado pela organização promove a participação de representante da área de negócio como integrante da equipe de desenvolvimento ou aquisição de software, desde sua concepção até a aceitação final] |
| N/A                                                                                                                                                                                                                                                                                                                                                                            |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] o processo de software da organização promove a identificação precoce de requisitos de segurança da informação e a gestão permanente desses requisitos durante todo o ciclo de vida do software]                               |
| N/A                                                                                                                                                                                                                                                                                                                                                                            |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o processo de software da organização promove a identificação precoce de requisitos de acessibilidade e de usabilidade, bem como a gestão permanente desses requisitos durante todo o ciclo de vida do software]               |
| N/A                                                                                                                                                                                                                                                                                                                                                                            |

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) a organização assegura os seus direitos autorais, de propriedade e de uso relativamente ao software que desenvolve por meio de contratação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) organização avalia, por meio de mensurações, indicadores e metas, a qualidade do software desenvolvido ou adquirido]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) o processo de software está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do processo de software, como: norma ou metodologia de desenvolvimento/aquisição; documentos de requisitos; participação das áreas de negócio; registros de testes e validações; critérios de segurança, acessibilidade e usabilidade; indicadores de qualidade; contratos com cláusulas de propriedade intelectual; fluxos ou ferramentas de desenvolvimento; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de software, como: norma ou metodologia de desenvolvimento/aquisição; documentos de requisitos; participação das áreas de negócio; registros de testes e validações; critérios de segurança, acessibilidade e usabilidade; indicadores de qualidade; contratos com cláusulas de propriedade intelectual; fluxos ou ferramentas de desenvolvimento; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Soluções e Projetos de TI

2602. A organização executa processo de gestão de projetos de tecnologia da informação. A gestão de projetos de TI consiste em planejar, executar, acompanhar e controlar projetos de tecnologia da informação, assegurando o gerenciamento de escopo, prazo, custos, recursos, riscos e resultados.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) a organização possui base de dados consolidada (portfólio) de projetos de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) escopo, custos, uso de recursos e cumprimento de prazos são gerenciados em cada projeto]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) é realizada a gestão de riscos de cada um dos projetos de alta materialidade ou alta relevância]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) o processo de gestão de projetos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da gestão de projetos de TI, como: portfólio de projetos; planos de projeto; cronogramas; registros de acompanhamento de escopo, custos e prazos; análises e planos de tratamento de riscos; relatórios de status; metodologia ou norma formal de gestão de projetos; indicadores de desempenho; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da gestão de projetos de TI, como: portfólio de projetos; planos de projeto; cronogramas; registros de acompanhamento de escopo, custos e prazos; análises e planos de tratamento de riscos; relatórios de status; metodologia ou norma formal de gestão de projetos; indicadores de desempenho; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2701. Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão de tecnologia da informação estão definidos e documentados. Os perfis profissionais de gestão definem as responsabilidades, atribuições, competências e habilidades esperadas dos ocupantes de cargos de liderança e gestão, promovendo transparência, clareza de papéis e melhor seleção de gestores.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] as responsabilidades e atribuições dos gestores da área de tecnologia da informação estão definidas, documentadas e publicadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] as responsabilidades e atribuições dos gestores da área de tecnologia da informação são revisadas periodicamente e publicadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] relacionou-se, no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências e habilidades que os ocupantes dos cargos de gestão devem possuir]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos para as ocupações de gestão]

N/A

Caso tenha assinalado que adota a prática, forneça evidência dos perfis profissionais de gestão, como: normativos ou documentos com atribuições e competências; descrições de cargos ou funções; matrizes de competências; registros de revisão periódica; publicações em portal institucional ou transparência ativa; atos de designação; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência dos perfis profissionais de gestão, como: normativos ou documentos com atribuições e competências; descrições de cargos ou funções; matrizes de competências; registros de revisão periódica; publicações em portal institucional ou transparência ativa; atos de designação; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2702. Os perfis profissionais desejados para cada ocupação ou grupo de colaboradores da área de gestão de tecnologia da informação estão definidos e documentados. Os perfis profissionais da área de TI definem responsabilidades, atribuições, competências e habilidades esperadas dos colaboradores que atuam em tecnologia da informação, apoiando a organização, a capacitação e a gestão da força de trabalho de TI.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação são revisadas periodicamente e publicadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] relacionou-se, no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências e habilidades que os ocupantes dos cargos devem possuir]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos]

N/A

Caso tenha assinalado que adota a prática, forneça evidência dos perfis profissionais da área de TI, como: descrições de cargos ou funções; matrizes de competências; normativos com atribuições e responsabilidades; registros de revisão periódica; publicações em portal institucional ou mecanismos de transparência; planos de capacitação relacionados; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência dos perfis profissionais da área de TI, como: descrições de cargos ou funções; matrizes de competências; normativos com atribuições e responsabilidades; registros de revisão periódica; publicações em portal institucional ou mecanismos de transparência; planos de capacitação relacionados; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2703. Há definição do quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação. A definição do quantitativo necessário de pessoal de TI consiste em estimar, de forma planejada e documentada, a quantidade de profissionais necessária para executar atividades de tecnologia da informação e segurança da informação na organização.

Adota em menor parte.

Indique que leis e/ou normas são essas:

|                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                                                                |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                                                            |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] há política de orientação para o dimensionamento da força de trabalho]                                                                                                                                                                                                                                    |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] definiu-se o quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação com base em critério(s) ou procedimento(s) técnico(s)]                                                                                                                                      |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação]                                                                                                                                                                  |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] há revisão periódica do quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação]                                                                                                                                                                                 |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Caso tenha assinalado que adota a prática, forneça evidência do dimensionamento da força de trabalho de TI, como: política ou metodologia de dimensionamento; estudos ou relatórios técnicos; definição documentada do quantitativo necessário; critérios utilizados (serviços, sistemas, demanda, riscos ou complexidade); revisões periódicas; planos de provimento; ou outras evidências cabíveis, indicando a abrangência na organização.             |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência do dimensionamento da força de trabalho de TI, como: política ou metodologia de dimensionamento; estudos ou relatórios técnicos; definição documentada do quantitativo necessário; critérios utilizados (serviços, sistemas, demanda, riscos ou complexidade); revisões periódicas; planos de provimento; ou outras evidências cabíveis, indicando a abrangência na organização. |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

## Gestão de Pessoas em Tecnologia da Informação

|                                                                                                                                                                                                                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2704. A escolha dos gestores de tecnologia da informação e segurança da informação ocorre segundo perfis profissionais previamente definidos e documentados.A escolha de gestores de TI e segurança da informação com base em perfis profissionais consiste em utilizar critérios previamente definidos de competências, experiência, integridade e habilidades para ocupação de cargos e funções de gestão. |
| Adota em menor parte.                                                                                                                                                                                                                                                                                                                                                                                        |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                                      |
|                                                                                                                                                                                                                                                                                                                                                                                                              |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                   |
|                                                                                                                                                                                                                                                                                                                                                                                                              |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                               |
|                                                                                                                                                                                                                                                                                                                                                                                                              |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] avalia-se, previamente à nomeação/designação, se o gestor possui impedimentos legais decorrentes de sanções administrativas, cíveis, eleitorais ou penais, incluindo envolvimento em atos de corrupção]                                                      |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                          |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado]                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                          |

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) são utilizadas ferramentas estruturadas para auxiliar a seleção dos ocupantes dos cargos/funções comissionados de gestão]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) são utilizados mecanismos de transparência ativa para disponibilizar às partes interessadas externas e internas o currículo dos ocupantes dos cargos/funções de gestão]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do processo de escolha de gestores de TI e segurança da informação, como: perfis profissionais documentados; critérios de seleção; registros de avaliação prévia de impedimentos legais; utilização de entrevistas, análises curriculares ou outras ferramentas estruturadas; currículos publicados; atos de designação; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de escolha de gestores de TI e segurança da informação, como: perfis profissionais documentados; critérios de seleção; registros de avaliação prévia de impedimentos legais; utilização de entrevistas, análises curriculares ou outras ferramentas estruturadas; currículos publicados; atos de designação; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2705. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação são identificadas e documentadas. A identificação de lacunas de competências consiste em avaliar e registrar conhecimentos, habilidades e capacidades que precisam ser desenvolvidos pelos colaboradores e gestores de TI e segurança da informação para atender às necessidades da organização.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) as lacunas de competências pessoais (transversais, comuns a todos os colaboradores) da organização são identificadas e documentadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da identificação de lacunas de competências, como: matrizes de competências; avaliações de perfil; levantamentos de necessidades de capacitação; diagnósticos de competências técnicas e gerenciais; planos de desenvolvimento; relatórios ou registros documentados; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da identificação de lacunas de competências, como: matrizes de competências; avaliações de perfil; levantamentos de necessidades de capacitação; diagnósticos de competências técnicas e gerenciais; planos de desenvolvimento; relatórios ou registros documentados; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2706. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação da organização são tratadas. O tratamento de lacunas de competências consiste em executar ações para desenvolver conhecimentos, habilidades e capacidades necessárias aos colaboradores e gestores de TI e segurança da informação, de acordo com as necessidades da organização.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização incentiva seus colaboradores e gestores a participar das ações de capacitação existentes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a organização monitora a participação dos colaboradores e gestores nas ações de capacitação existentes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a organização analisa periódica e criticamente o plano de capacitação (plano de treinamento) existente]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do tratamento de lacunas de competências, como: plano de capacitação ou treinamento; registros de participação em cursos e treinamentos; ações de incentivo à capacitação; acompanhamento de participação e resultados; revisões periódicas do plano de capacitação; contratações ou apoio especializado; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do tratamento de lacunas de competências, como: plano de capacitação ou treinamento; registros de participação em cursos e treinamentos; ações de incentivo à capacitação; acompanhamento de participação e resultados; revisões periódicas do plano de capacitação; contratações ou apoio especializado; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2707. A organização realiza, formalmente, avaliação de desempenho individual do pessoal de tecnologia da informação e de segurança da informação, com atribuição de nota ou conceito, tendo como critério de avaliação o alcance das metas previstas. A avaliação de desempenho do pessoal de TI e segurança da informação consiste em medir formalmente o desempenho de colaboradores e gestores, considerando metas, resultados, competências e responsabilidades relacionadas às atividades exercidas.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] há normativo que trata da avaliação de desempenho dos colaboradores e gestores]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a avaliação abrange o desempenho dos gestores da área de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a avaliação abrange o desempenho dos gestores da área de segurança da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a avaliação abrange o desempenho dos colaboradores da área de tecnologia da informação]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a avaliação abrange o desempenho dos colaboradores da área de segurança da informação]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da avaliação de desempenho do pessoal de TI e segurança da informação, como: normativos ou procedimentos de avaliação; formulários ou sistemas utilizados; critérios e metas avaliadas; registros de avaliações realizadas; atribuição de notas ou conceitos; planos de melhoria decorrentes das avaliações; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da avaliação de desempenho do pessoal de TI e segurança da informação, como: normativos ou procedimentos de avaliação; formulários ou sistemas utilizados; critérios e metas avaliadas; registros de avaliações realizadas; atribuição de notas ou conceitos; planos de melhoria decorrentes das avaliações; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Pessoas em Tecnologia da Informação

2708. A organização possui em sua estrutura cargos específicos em tecnologia da informação e segurança da informação. Os cargos específicos de TI e segurança da informação são funções ou cargos formalmente previstos na estrutura organizacional para execução de atividades técnicas, gerenciais ou especializadas relacionadas à tecnologia e à proteção das informações. [a] a organização possui em sua estrutura cargos efetivos em tecnologia da informação]

Não

2708. A organização possui em sua estrutura cargos específicos em tecnologia da informação e segurança da informação. Os cargos específicos de TI e segurança da informação são funções ou cargos formalmente previstos na estrutura organizacional para execução de atividades técnicas, gerenciais ou especializadas relacionadas à tecnologia e à proteção das informações. [b] a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação]

Não

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2708. A organização possui em sua estrutura cargos específicos em tecnologia da informação e segurança da informação. Os cargos específicos de TI e segurança da informação são funções ou cargos formalmente previstos na estrutura organizacional para execução de atividades técnicas, gerenciais ou especializadas relacionadas à tecnologia e à proteção das informações. [c] a organização possui em sua estrutura cargos efetivos em segurança da informação]                                 |
| Não                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| 2708. A organização possui em sua estrutura cargos específicos em tecnologia da informação e segurança da informação. Os cargos específicos de TI e segurança da informação são funções ou cargos formalmente previstos na estrutura organizacional para execução de atividades técnicas, gerenciais ou especializadas relacionadas à tecnologia e à proteção das informações. [d] a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação] |
| Não                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Caso tenha assinalado que adota a prática, forneça evidência da existência de cargos específicos de TI e segurança da informação, como: leis, decretos ou normativos de criação de cargos; organogramas; planos de cargos e carreiras; editais de concurso; descrição de atribuições; relação de cargos providos; ou outras evidências cabíveis, indicando a abrangência na organização.                                                                                                             |
| [{"title":"Organograma - nao consegui passar para o proximo questionario sem colocar o organograma .","comment":"","size":"711.65625","name":"organograma.docx","filename":"fu_er36ufb2apihia","ext":"docx" }]                                                                                                                                                                                                                                                                                       |
| filecount - Caso tenha assinalado que adota a prática, forneça evidência da existência de cargos específicos de TI e segurança da informação, como: leis, decretos ou normativos de criação de cargos; organogramas; planos de cargos e carreiras; editais de concurso; descrição de atribuições; relação de cargos providos; ou outras evidências cabíveis, indicando a abrangência na organização.                                                                                                 |
| 1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

## Gestão de Contratações de Tecnologia da Informação

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2801. Os processos de trabalho relativos às contratações de tecnologia da informação estão definidos. Os processos de trabalho relativos às contratações de TI consistem na definição formal das etapas, responsabilidades, procedimentos, controles e documentos relacionados ao planejamento da contratação, à seleção de fornecedores e à gestão e fiscalização contratual. A padronização de artefatos contribui para uniformizar procedimentos, reduzir falhas e aumentar a conformidade das contratações. Adota em menor parte. |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa]                                                                                                                                                                                                           |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] são disponibilizados artefatos padronizados para a fase de planejamento das contratações de TI, como Documento de Formalização da Demanda (DFD), Estudo Técnico Preliminar (ETP), Termo de Referência (TR), Matriz de Riscos ou documentos equivalentes]                                                                                                                              |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa]                                                                                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes]                                                                                                                                                                                       |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) são disponibilizados artefatos padronizados para a gestão e fiscalização de contratos de TI, como modelos de plano de fiscalização, termos de recebimento, relatórios de acompanhamento, registros de ocorrências, avaliações de desempenho contratual ou documentos equivalentes]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g) os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas]

N/A

Caso tenha assinalado que adota a prática, forneça evidência dos processos de trabalho e dos artefatos padronizados relativos às contratações de TI, como: manuais, fluxos, normas ou procedimentos internos; modelos padronizados de documentos; checklists; definição de papéis e responsabilidades; fluxogramas; instruções de trabalho; artefatos de planejamento da contratação; processos de fiscalização contratual; referências à Lei 14.133/2021 e normativos correlatos; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência dos processos de trabalho e dos artefatos padronizados relativos às contratações de TI, como: manuais, fluxos, normas ou procedimentos internos; modelos padronizados de documentos; checklists; definição de papéis e responsabilidades; fluxogramas; instruções de trabalho; artefatos de planejamento da contratação; processos de fiscalização contratual; referências à Lei 14.133/2021 e normativos correlatos; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Contratações de Tecnologia da Informação

2802. A organização executa processo de planejamento anual das contratações. O planejamento anual das contratações consiste em consolidar e priorizar, de forma planejada e coordenada, as necessidades de contratação da organização para determinado exercício, considerando objetivos institucionais, orçamento e demandas das áreas envolvidas.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) a alta administração (ou conselho ou colegiado superior) aprova formalmente o Plano de Contratações Anual (PCA)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) os setores relevantes da organização participam da elaboração do PCA]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) na elaboração do PCA são considerados os demais instrumentos de planejamento da organização]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) o PCA fundamenta a proposta orçamentária da organização]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] a organização divulga o PCA e as eventuais alterações do plano no Portal Nacional de Compras Públicas (PNCP)]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do processo de planejamento anual das contratações, como: Plano de Contratações Anual (PCA); normativos ou procedimentos relacionados; registros de participação das áreas envolvidas; aprovação pela alta administração; integração com planejamento institucional e orçamento; publicação no PNCP; cronogramas; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do processo de planejamento anual das contratações, como: Plano de Contratações Anual (PCA); normativos ou procedimentos relacionados; registros de participação das áreas envolvidas; aprovação pela alta administração; integração com planejamento institucional e orçamento; publicação no PNCP; cronogramas; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Contratações de Tecnologia da Informação

2803. A organização torna públicos os documentos relacionados com cada contratação de tecnologia da informação, contemplando as fases de planejamento, seleção do fornecedor e gestão contratual, excepcionados os casos de sigilo amparados pela legislação. A transparência das contratações consiste em disponibilizar publicamente documentos e informações relacionados às fases de planejamento, seleção de fornecedores e gestão contratual, permitindo o acompanhamento, controle social e fiscalização das contratações públicas, ressalvadas hipóteses legais de sigilo.

Adota em menor parte.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] o Estudo Técnico Preliminar (ETP) das contratações é publicado no Portal Nacional de Compras Públicas (PNCP)]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] o Termo de Referência (TR) ou projeto básico das contratações é publicado no PNCP]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] o edital de credenciamento e de pré-qualificação, o aviso de contratação direta e o edital de licitação e respectivos anexos são publicados no PNCP]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] a ata de registro de preços, a ata de julgamento, contendo propostas e lances oferecidos (quando for o caso) são publicadas no PNCP]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] o inteiro teor dos contratos, notas de empenho, aditivos e termos de prorrogação de contratos são publicados no PNCP]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f] os termos de recebimentos provisórios e definitivos são publicados no PNCP]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g) a análise realizada e justificativa dada para subsidiar a decisão de prorrogação contratual são publicadas no PNCP]

N/A

Caso tenha assinalado que adota a prática, forneça evidência da transparência das contratações, como: links ou registros de publicação no Portal Nacional de Compras Públicas (PNCP); publicações de ETP, TR, editais, atas, contratos, aditivos e documentos de gestão contratual; normativos internos sobre transparência; relatórios de publicação; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência da transparência das contratações, como: links ou registros de publicação no Portal Nacional de Compras Públicas (PNCP); publicações de ETP, TR, editais, atas, contratos, aditivos e documentos de gestão contratual; normativos internos sobre transparência; relatórios de publicação; ou outras evidências cabíveis, indicando a abrangência na organização.

## Gestão de Contratações de Tecnologia da Informação

2804. No fluxo de contratação e gestão de contratos de soluções de tecnologia da informação, a organização adota as seguintes práticas de governança e controle: A governança nas contratações de TI exige que as aquisições estejam alinhadas ao planejamento, possuam viabilidade técnica atestada pela área especializada, sejam construídas por equipes multidisciplinares e fiscalizadas com segregação de funções, garantindo que o pagamento esteja vinculado a resultados. [a) as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI]

Não

2804. No fluxo de contratação e gestão de contratos de soluções de tecnologia da informação, a organização adota as seguintes práticas de governança e controle: A governança nas contratações de TI exige que as aquisições estejam alinhadas ao planejamento, possuam viabilidade técnica atestada pela área especializada, sejam construídas por equipes multidisciplinares e fiscalizadas com segregação de funções, garantindo que o pagamento esteja vinculado a resultados. [b) as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA)]

Sim

2804. No fluxo de contratação e gestão de contratos de soluções de tecnologia da informação, a organização adota as seguintes práticas de governança e controle: A governança nas contratações de TI exige que as aquisições estejam alinhadas ao planejamento, possuam viabilidade técnica atestada pela área especializada, sejam construídas por equipes multidisciplinares e fiscalizadas com segregação de funções, garantindo que o pagamento esteja vinculado a resultados. [c) a fase de planejamento de cada contratação de TI é conduzida por uma Equipe de Planejamento da Contratação formalmente designada (composta, minimamente, por integrante requisitante e integrante técnico da área de TI)]

Não

2804. No fluxo de contratação e gestão de contratos de soluções de tecnologia da informação, a organização adota as seguintes práticas de governança e controle: A governança nas contratações de TI exige que as aquisições estejam alinhadas ao planejamento, possuam viabilidade técnica atestada pela área especializada, sejam construídas por equipes multidisciplinares e fiscalizadas com segregação de funções, garantindo que o pagamento esteja vinculado a resultados. [d) os Termos de Referência (TR) ou Projetos Básicos preveem Níveis Mínimos de Serviço (NMS), vinculando o pagamento à efetiva entrega de resultados ou níveis de qualidade, evitando o mero pagamento por postos de trabalho ou horas trabalhadas]

Sim

2804. No fluxo de contratação e gestão de contratos de soluções de tecnologia da informação, a organização adota as seguintes práticas de governança e controle: A governança nas contratações de TI exige que as aquisições estejam alinhadas ao planejamento, possuam viabilidade técnica atestada pela área especializada, sejam construídas por equipes multidisciplinares e fiscalizadas com segregação de funções, garantindo que o pagamento esteja vinculado a resultados. [e) a fase de planejamento das contratações de TI inclui a análise expressa de requisitos de segurança da informação e de proteção de dados pessoais (adequação à LGPD)]

Sim

Caso tenha assinalado que as contratações de soluções de TI são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI, forneça evidência de norma regulamentando esse processo e de um caso concreto.

filecount - Caso tenha assinalado que as contratações de soluções de TI são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI, forneça evidência de norma regulamentando esse processo e de um caso concreto.

## Gestão de Contratações de Tecnologia da Informação

2805. Nas contratações de bens e serviços de Tecnologia da Informação, a organização faz uso das Notas Técnicas elaboradas pelo TCE-RJ. O uso das Notas Técnicas do TCE-RJ consiste em considerar orientações, recomendações e boas práticas elaboradas pelo Tribunal para apoiar o planejamento, a instrução, a contratação e a fiscalização de bens e serviços de tecnologia da informação. [a] a Nota Técnica TCE-RJ n. 06/2023]

Sim

2805. Nas contratações de bens e serviços de Tecnologia da Informação, a organização faz uso das Notas Técnicas elaboradas pelo TCE-RJ. O uso das Notas Técnicas do TCE-RJ consiste em considerar orientações, recomendações e boas práticas elaboradas pelo Tribunal para apoiar o planejamento, a instrução, a contratação e a fiscalização de bens e serviços de tecnologia da informação. [b] a Nota Técnica TCE-RJ n. 08/2024]

Sim

## Inteligência Artificial

3001. A organização utiliza inteligência artificial de forma institucional em suas operações. O uso institucional de inteligência artificial ocorre quando a organização conhece, autoriza, contrata, desenvolve ou supervisiona soluções de IA utilizadas em processos internos, atividades finalísticas ou serviços prestados ao cidadão.

Não adota.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização identifica e avalia continuamente oportunidades de aplicação de inteligência artificial alinhadas às suas necessidades institucionais]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b] a organização executa projetos-piloto ou provas de conceito (POC) envolvendo inteligência artificial]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c] a organização desenvolve internamente soluções de inteligência artificial para suportar suas necessidades institucionais]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d] soluções de inteligência artificial já operam em produção apoiando processos administrativos internos]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e] soluções de inteligência artificial já operam em produção apoiando atividades finalísticas ou serviços prestados diretamente ao cidadão]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) a organização designou formalmente uma equipe, comitê ou responsáveis técnicos pelas iniciativas e projetos de inteligência artificial]

N/A

Caso tenha assinalado que adota a prática, forneça evidência do uso de inteligência artificial, como: relação de sistemas ou soluções com IA; projetos ou provas de conceito (POC); contratos ou aquisições; fluxos automatizados; documentos técnicos; relatórios de uso; exemplos de aplicações em processos internos ou serviços ao cidadão; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência do uso de inteligência artificial, como: relação de sistemas ou soluções com IA; projetos ou provas de conceito (POC); contratos ou aquisições; fluxos automatizados; documentos técnicos; relatórios de uso; exemplos de aplicações em processos internos ou serviços ao cidadão; ou outras evidências cabíveis, indicando a abrangência na organização.

## Inteligência Artificial

3002. A organização estabeleceu diretrizes para o uso da inteligência artificial. As diretrizes para uso de inteligência artificial definem regras, responsabilidades e controles para utilização segura, ética e alinhada aos objetivos da organização, incluindo aspectos como riscos, proteção de dados e supervisão humana.

Não adota.

Indique que leis e/ou normas são essas:

Identifique esses estudos:

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a) a organização instituiu política ou norma interna com diretrizes claras para utilização ética e segura de inteligência artificial]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) há regras e restrições formais sobre a utilização de dados institucionais não públicos, dados pessoais ou sensíveis como "insumos" (prompts) em ferramentas de IA]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) a organização informa ao usuário, quando aplicável, que ele está interagindo com solução de inteligência artificial ou que determinado serviço, resposta ou decisão contou com apoio de IA]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) a organização estabelece a obrigatoriedade de avaliação de riscos antes da implantação de soluções de IA]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [e) a organização adota mecanismos de revisão humana, garantindo que decisões sugeridas por IA não sejam aplicadas de forma totalmente autônoma]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [f) a organização realiza testes, validações ou avaliações antes da utilização institucional de soluções de IA]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [g) a organização realiza ações regulares de conscientização ou capacitação sobre uso responsável de inteligência artificial]

N/A

Caso tenha assinalado que adota a prática, forneça evidência das diretrizes para uso de inteligência artificial, como: política, norma ou guia institucional; definição de responsabilidades; regras para uso de dados pessoais e informações sensíveis; avaliações de riscos; registros de supervisão ou revisão humana; ações de conscientização ou capacitação; atas de comitês ou grupos de trabalho; ou outras evidências cabíveis, indicando a abrangência na organização.

filecount - Caso tenha assinalado que adota a prática, forneça evidência das diretrizes para uso de inteligência artificial, como: política, norma ou guia institucional; definição de responsabilidades; regras para uso de dados pessoais e informações sensíveis; avaliações de riscos; registros de supervisão ou revisão humana; ações de conscientização ou capacitação; atas de comitês ou grupos de trabalho; ou outras evidências cabíveis, indicando a abrangência na organização.

## Inteligência Artificial

3003. A organização já realizou contratação de soluções ou serviços que utilizam inteligência artificial. [a) a organização contratou soluções de software como serviço (SaaS) ou plataformas que possuem funcionalidades de IA para atividades específicas (ex: análise de fraudes, reconhecimento facial, chatbots)]

Não

3003. A organização já realizou contratação de soluções ou serviços que utilizam inteligência artificial. [b) a organização contratou soluções de inteligência artificial generativa (ex.: ChatGPT, Gemini, Claude, Copilot ou ferramentas equivalentes)]

Não

3003. A organização já realizou contratação de soluções ou serviços que utilizam inteligência artificial. [c) a organização contratou serviços especializados relacionados à inteligência artificial (consultoria, treinamento, desenvolvimento ou sustentação)]

Não

Caso tenha assinalado que realizou contratações relacionadas à inteligência artificial, forneça alguma evidência das soluções ou serviços contratados, como: editais e/ou contratos, estudos técnicos preliminares (ETP), documentos de formalização da demanda (DFD) e número de processo SEI.

filecount - Caso tenha assinalado que realizou contratações relacionadas à inteligência artificial, forneça alguma evidência das soluções ou serviços contratados, como: editais e/ou contratos, estudos técnicos preliminares (ETP), documentos de formalização da demanda (DFD) e número de processo SEI.

3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [a) Dificuldade para identificar e comparar soluções disponíveis no mercado (fornecedores, funcionalidades, maturidade das ofertas e experiências de outros órgãos).]

N/A

3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [b) Dificuldade para definir claramente o objeto, escopo, entregas e responsabilidades da contratação.]

N/A

3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [c) Dificuldade para especificar requisitos técnicos e funcionais da solução (integrações, desempenho, rastreabilidade, registros de auditoria, explicabilidade ou requisitos de infraestrutura).]

N/A

3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [d) Dificuldade para estimar preços, quantitativos ou consumo da solução (usuários, processamento, chamadas de API, armazenamento, tokens ou escalabilidade).]

N/A

|                                                                                                                                                                                                                                                                                                                                                        |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [e] Dificuldade para estimar o custo total da solução ao longo do tempo (implantação, operação, suporte, treinamento, segurança, monitoramento e evolução).]        |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [f] Dificuldade para definir o modelo de contratação mais adequado (SaaS, plataforma em nuvem, desenvolvimento sob demanda, serviço gerenciado ou licenciamento).]  |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [g] Dificuldade para definir critérios objetivos de julgamento, avaliação técnica ou comprovação de capacidade dos fornecedores.]                                   |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [h] Dificuldade para elaborar artefatos de planejamento e termos de referência com requisitos e critérios verificáveis.]                                            |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [i] Dificuldade para planejar implantação, integração, migração, treinamento de usuários ou gestão da mudança organizacional.]                                      |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [j] Dificuldade para definir mecanismos de acompanhamento, fiscalização, transparência, auditoria ou penalidades contratuais.]                                      |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [k] Dificuldade para integrar soluções de IA aos sistemas corporativos existentes.]                                                                                 |
| N/A                                                                                                                                                                                                                                                                                                                                                    |
| 3004. Quais foram as principais dificuldades enfrentadas pela organização na fase de planejamento e contratação de soluções ou serviços que utilizam inteligência artificial (IA)? [l] Dificuldade para definir exigências de Proteção de Dados, LGPD e garantias de que os dados do órgão não serão utilizados para treinamento de modelos públicos.] |
| N/A                                                                                                                                                                                                                                                                                                                                                    |

## Inteligência Artificial

|                                                                                                                                                                                                                                                                                                                                                                                                        |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 3005. A organização adota medidas para identificar e controlar o uso não autorizado ou não mapeado de inteligência artificial generativa. O uso não autorizado ou não mapeado de IA generativa ocorre quando agentes públicos utilizam ferramentas como ChatGPT, Gemini, Claude, Copilot ou similares em atividades de trabalho sem conhecimento, autorização, diretrizes ou supervisão institucional. |
| Não adota.                                                                                                                                                                                                                                                                                                                                                                                             |
| Indique que leis e/ou normas são essas:                                                                                                                                                                                                                                                                                                                                                                |
|                                                                                                                                                                                                                                                                                                                                                                                                        |
| Identifique esses estudos:                                                                                                                                                                                                                                                                                                                                                                             |
|                                                                                                                                                                                                                                                                                                                                                                                                        |
| Explique que razões são essas:                                                                                                                                                                                                                                                                                                                                                                         |
|                                                                                                                                                                                                                                                                                                                                                                                                        |
| Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [a] a organização identifica quais ferramentas públicas de IA generativa (gratuitas ou contas pessoais) estão sendo acessadas na rede corporativa]                                                                                                         |
| N/A                                                                                                                                                                                                                                                                                                                                                                                                    |

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [b) a organização definiu ferramentas de IA generativa autorizadas, restritas ou vedadas para uso em atividades de trabalho]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [c) a organização adota controles técnicos para reduzir o uso de ferramentas de IA generativa não homologadas/autorizadas]

N/A

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização: [d) a organização possui processo para avaliação e homologação de novas ferramentas de IA necessárias às atividades de trabalho]

N/A

Caso tenha assinalado que adota a prática, forneça evidência das medidas de identificação e controle do uso de IA generativa, como: levantamento de ferramentas utilizadas; norma ou orientação interna; campanhas de conscientização; registros de autorização; controles técnicos; avaliações de risco; comunicações aos usuários; ou outras evidências cabíveis.

filecount - Caso tenha assinalado que adota a prática, forneça evidência das medidas de identificação e controle do uso de IA generativa, como: levantamento de ferramentas utilizadas; norma ou orientação interna; campanhas de conscientização; registros de autorização; controles técnicos; avaliações de risco; comunicações aos usuários; ou outras evidências cabíveis.

## Inteligência Artificial

3006. Descreva os principais usos de inteligência artificial existentes na organização, indicando, quando possível, a finalidade, a área responsável, o estágio de utilização e se a solução é desenvolvida internamente, contratada ou disponibilizada por terceiro

Ainda não utilizamos a Inteligencia Artificial na Fundação.

## Complementar

Comentários: Utilize o espaço abaixo para registrar suas considerações acerca da pesquisa, incluindo críticas às questões, alertas para situações especiais não contempladas ou qualquer outra contribuição que considere válida. Tais comentários permitirão análise mais adequada dos dados encaminhados e melhorias para os próximos questionários.

O Nosso organograma foi instituído no ano de 1987 e ainda não foi atualizada.

A parte de segurança e feita através do FORTneT gerada e configurada pelo SNOC do PRODERJ / CLARO.

## Ciência

[Declaro estar ciente de que a responsabilidade pelas respostas dadas ao questionário é do dirigente máximo da organização, com base nas respostas providas pelos diversos setores da organização e reunidas por mim.]

Sim